

New Coworker

Infrastructure & Dependency Management Policy

Document owner: Engineering Leadership Version: 1.1 Effective: July 15, 2026 Review cycle: Annual

1. Purpose

This policy governs how New Coworker provisions, hardens, and maintains the infrastructure and third-party software dependencies behind newcoworker.com and the **New Coworker OAuth** Zoom Marketplace application.

2. Infrastructure Baseline

Layer	Provider / control
Web application	Vercel edge network; HTTPS-only with TLS 1.2+ negotiation; HSTS preload; immutable, reviewed deployments promoted from <code>main</code>
Database	Supabase-managed Postgres; row-level security on tenant tables; encrypted storage; service-role credentials confined to server environments
Background workers	Supabase Edge Functions; migrations and function bundles version-controlled and applied through the same review pipeline as application code
Secrets	Platform-encrypted environment configuration; never committed to source control; GitGuardian scanning enforces this on every pull request
Schema changes	Versioned SQL migrations in-repo; a CI drift check performs a dry-run push against the production migration ledger on every pull request so schema and code cannot diverge

3. Change Management

- All infrastructure-as-code, schema migrations, and CI configuration changes flow through pull requests with the same gate as application code: CodeQL SAST, lint, strict type-checking (TypeScript and Deno), dependency audit, the full test suite at 100% coverage, integration tests against a production-parity local database, and code review with every thread resolved.
- Production deploys are additionally blocked by an automated gate that verifies every check on the release commit is green before the deploy job may run.
- Rollback is a redeploy of the previous immutable build; schema migrations are written to be backward-compatible with the previous release.

4. Dependency Management

- **Inventory:** every dependency is pinned through lockfiles (`package-lock.json`) across all six npm workspaces (web app, email worker, LLM router, chat worker, voice bridge, render worker) plus GitHub Actions, giving a complete, reproducible software bill of inputs.

- **Updates:** Dependabot runs weekly on all ecosystems. Minor and patch updates are grouped and may auto-merge only after the entire CI gate passes; major versions always receive human review.
- **Vulnerability gates:** `npm audit` against production dependencies runs in two independent workflows on every pull request and push; any high-or-critical advisory fails the build and blocks merge.
- **Security advisories:** GitHub security advisories raise immediate Dependabot PRs outside the weekly cadence and are triaged under the Vulnerability Management Procedures response targets.
- **Provenance:** new dependencies require review for maintenance health and necessity; native/binary packages are isolated to server-only entry points.

5. Monitoring and Capacity

- Structured server-side logging with alerting on integration failures (including Zoom token refresh failures, which soft-disable the affected connection rather than degrade silently).
- Scheduled health checks cover background workers and voice infrastructure; failures notify the engineering channel.

6. Review

This policy is reviewed annually and whenever a new infrastructure provider or ecosystem is introduced.